Security Governance
Master of Science in Cyber Security

AA 2026/2027

INTRODUCTION

General Information

6 CFU all in the first semester
- September 23rd – December 19th



Instructors
- Silvia Bonomi
  - https://bonomi.diag.uniroma1.it/home
- Alessandro Palma
  - https://sites.google.com/diag.uniroma1.it/palma



General Information

Schedule

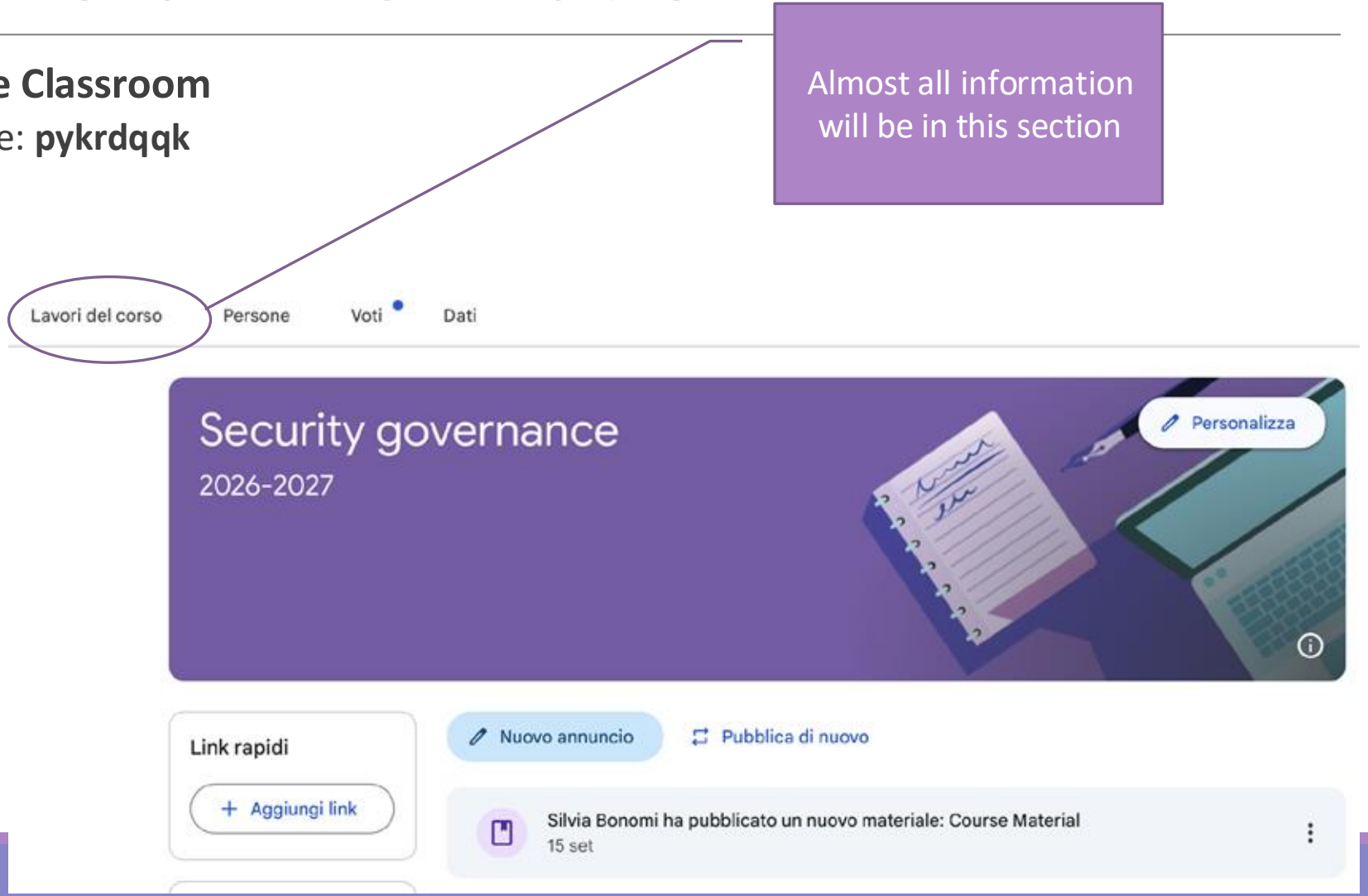
- Tuesday 9:00 – 12:00 Room 2L, Via del Castro Laurenziano 7a
- Friday 11:00 – 13:00 Room 1L, Via del Castro Laurenziano 7a

General Information

Google Classroom

- Code: **pykrdqqk**

Almost all information will be in this section



General Information

Students' hours

- During the semester: once a week by appointment
  - it is done in presence
  - it will be in the week following your request

- For brief questions you can ask
  - At the beginning/end of every lecture
  - During breaks

Where we are

- Our offices are at DIAG in Via Ariosto 25
  - Silvia Bonomi: room B114, 1st floor, B wing
  - Alessandro Palma: room B113, 1st floor, B wing

General Information

Material

- There is no a single book but multiple readings (the list will be available and updated on Classroom and references are in the slides)
- Scientific papers
- Technical Documents
- Slides

Exam

- written test

Introduction to Security Governance

Context Overview



Enterprise

Mission

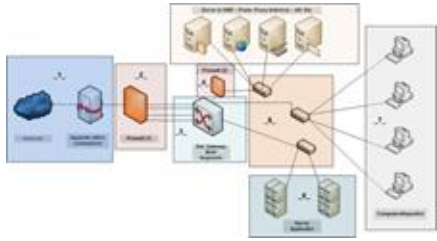
Examples

- Energy Providers
- Manufacturers
- Banks
- …









The concept of Governance

"Governance is all of the processes of governing, whether undertaken by a government, a market or a network, over a social system (family, tribe, formal organization or territory) and whether through laws, norms, power or language [organized society."

(Mark Bevir)

"The Governance is the processes of interaction among the actors involved in a collective problem that lead to the creation, reinforcement, or reproduction of social norms and institutions."

(Mayntz; Hufty)

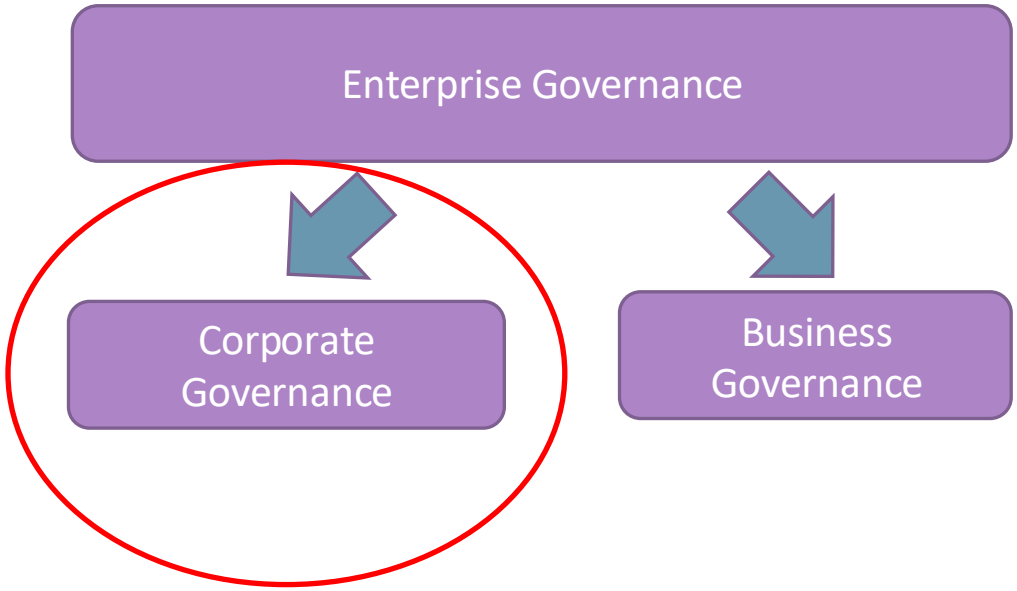
Processes

Norms

Enterprise Governance

"Enterprise governance is the structure and relationships that control, direct, or regulate the performance of an enterprise [and its] projects, portfolios, infrastructure, and processes" [1]

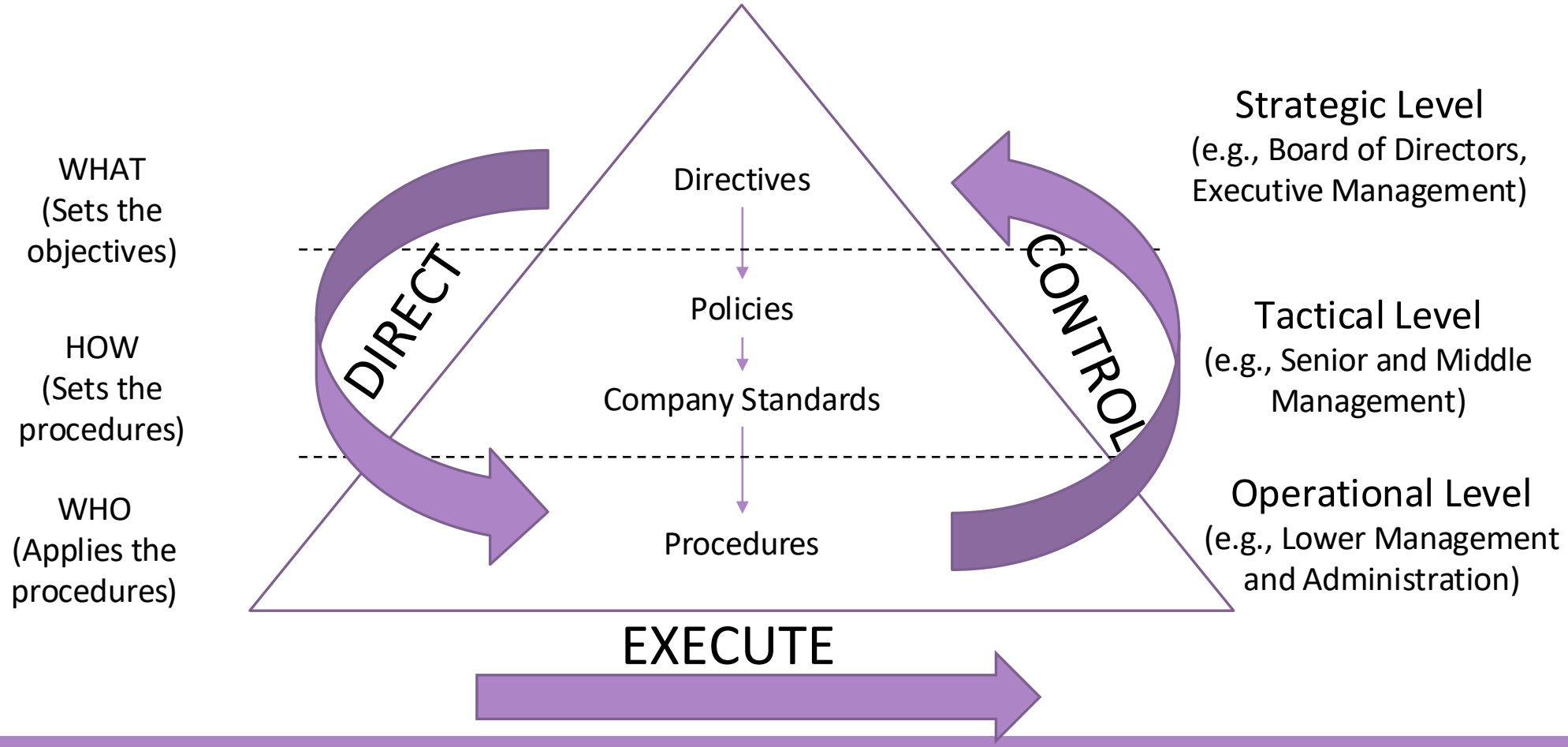
Corporate governance is the system of rules, practices and processes by which a firm is directed and controlled. (Compliance Processes)



Business Governance is a set of policies and business processes that set the way that the organisation's business is run. (Performance Processes)

[1] Wilson, W. L., 2009, *Conceptual Model for Enterprise Governance*, Ground System Architectures Workshop

Corporate Governance Direct/control loop



Context Overview



Enterprise

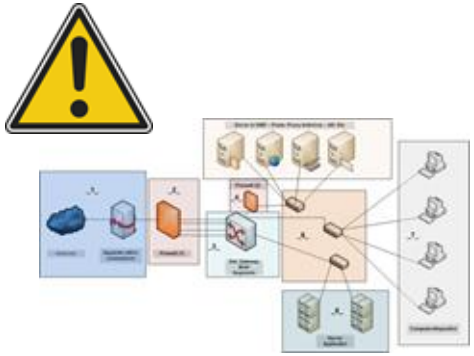
THREATS & VULNERABILITIES

- Bugs
- Errors
- Backdoors
- …









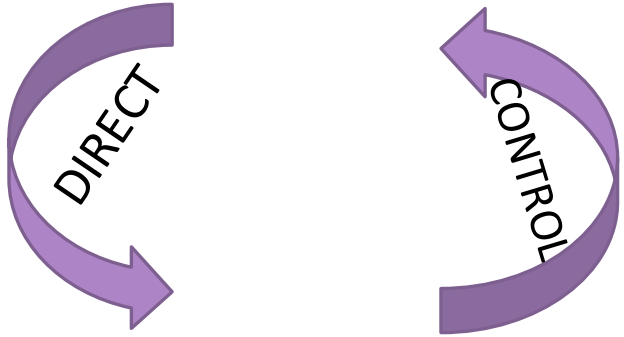
Corporate Governance and Risk Management

The Direct/Control loop is driven by Risks

- The IT Governance Institute redefine the concept of Enterprise (and thus Corporate) Governance as follow:

  "*Enterprise governance is a set of responsibilities and practices exercised by the board and executive management with the goal of providing strategic direction, ensuring that objectives are achieved, ascertaining that risks are managed appropriately and verifying that the enterprise's resources are used responsibly.*" [1]

Objective:
Reduce Risks

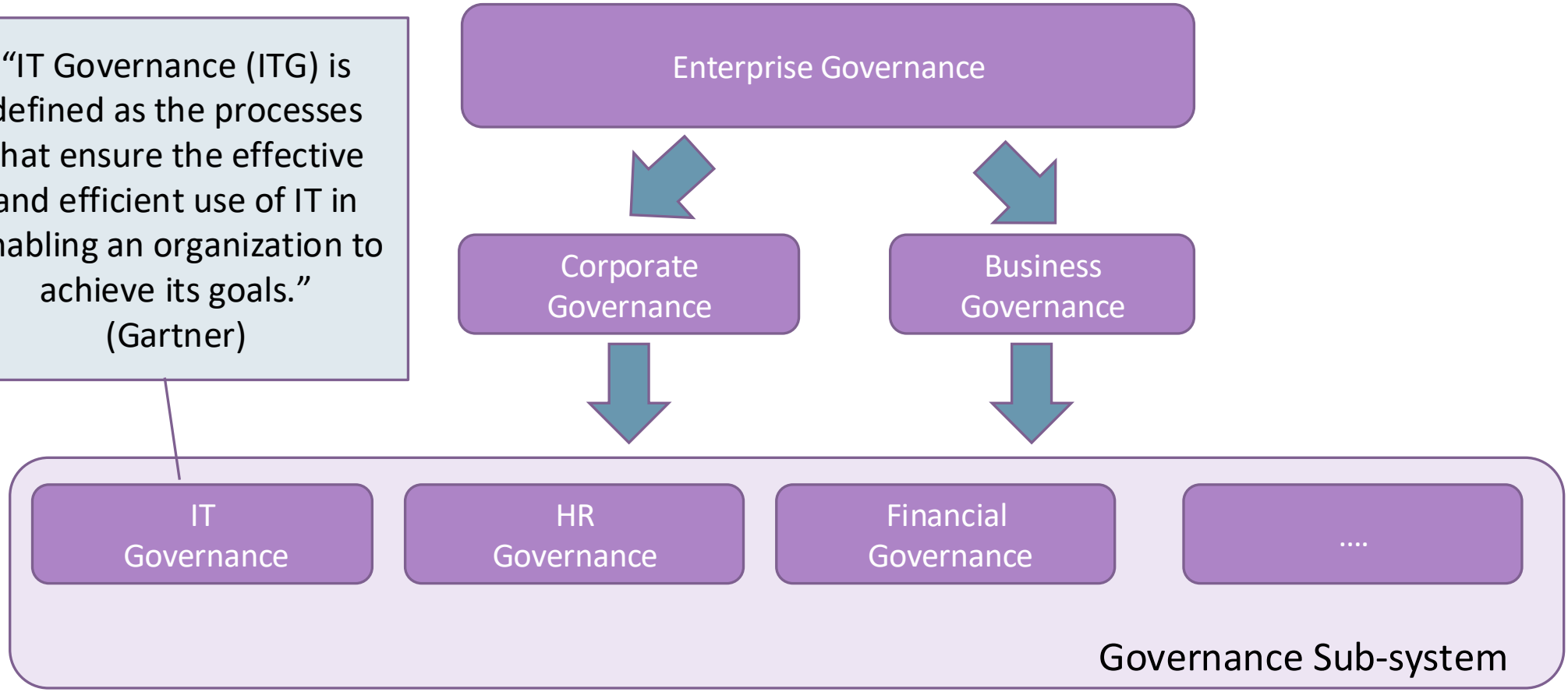


Objective:
Measure Risk Reduction

[1] Board Briefing IT Governance (2003). IT Governance Institute. Available at https://www.isaca.org/restricted/Documents/26904_Board_Briefing_final.pdf

Enterprise Governance Decomposition

"IT Governance (ITG) is defined as the processes that ensure the effective and efficient use of IT in enabling an organization to achieve its goals." (Gartner)



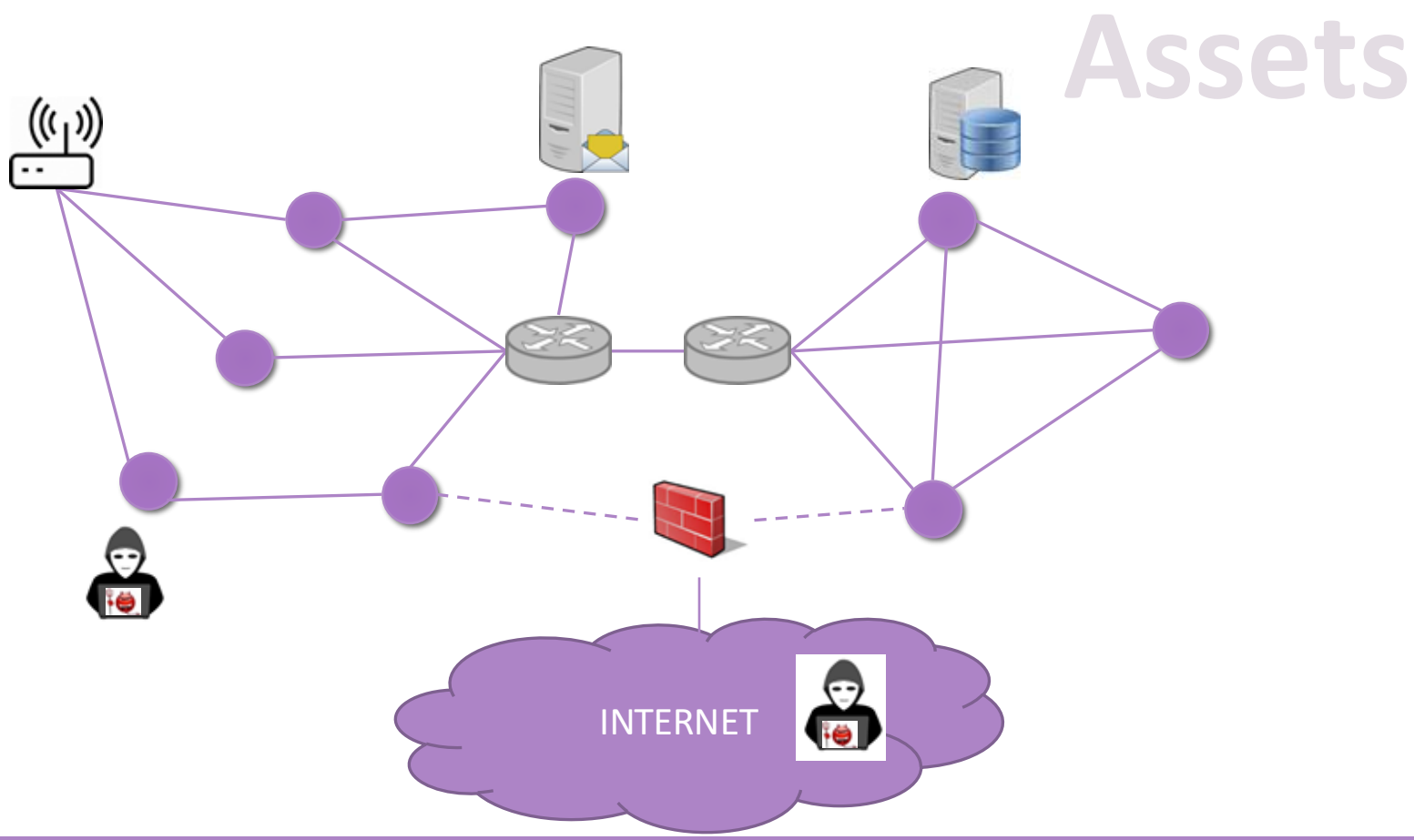
IT Governance and Risks

IT based systems causes serious risks to a company as it manages and stores many (if not all) electronic assets like

- Data and information stored
- Data and information transmitted over the network
- All the systems and application required to store, transmit and process data and information.

Electronic assets are exposed to many threats aiming at compromising their CIA properties (Confidentiality, Integrity and Availability)

IT Risks



Security Governance

"*Security governance is the means by which you control and direct your organisation's approach to security.*"

(UK National Cyber Security Centre)

When done well, security governance will effectively coordinate the security activities of your organisation.

It enables the flow of security information and decisions around your organisation.

Which approach to security governance is right for me?

There is no “one size fits all” approach to security governance.



formalised security framework, with clearly defined roles and business processes

informal approach to directing, controlling and making security decisions

Where my company should stay in this spectrum?

Which approach to security governance is right for me?



formalised security framework, with clearly defined roles and business processes

informal approach to directing, controlling and making security decisions

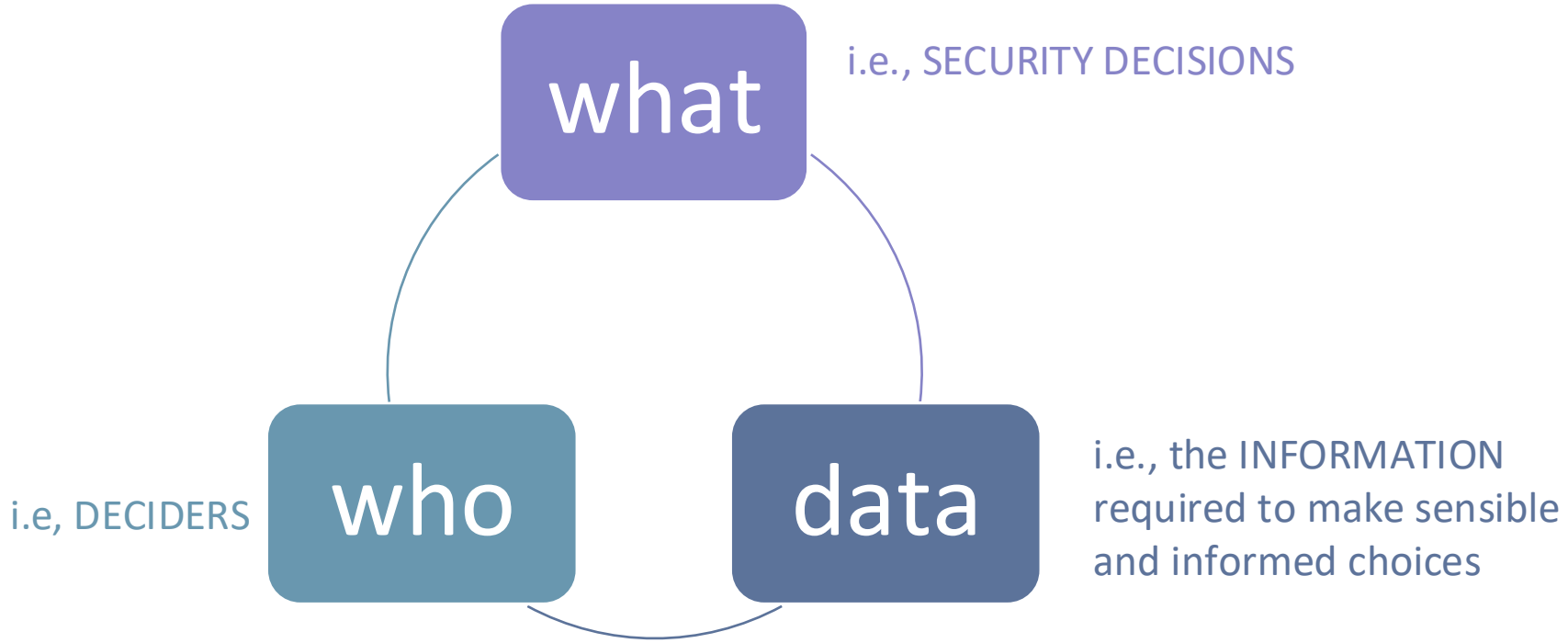
Where should my company stay in this spectrum?

Answer to these question helps in understanding the right level of formalisation

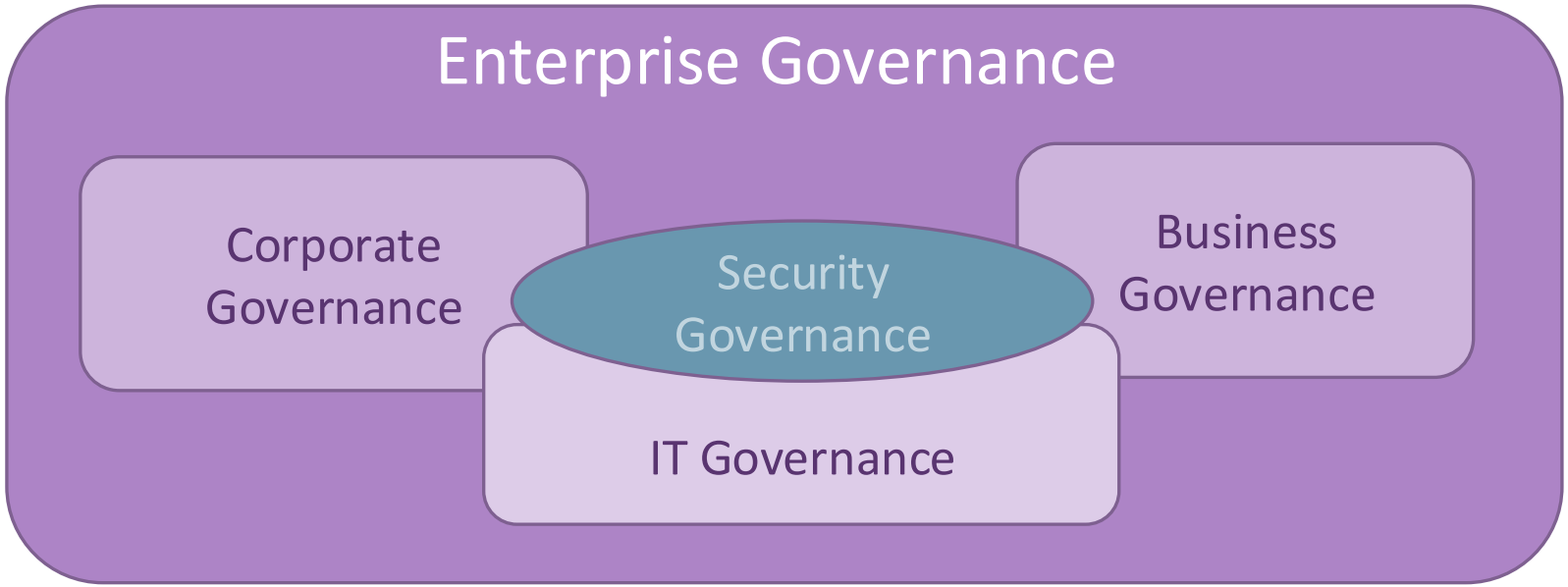
- How large and complex is your organisation?
- What resources are available for security governance?
- What does your organisation do and how important is security to those aims?
- Are there any external considerations (for example contractual, legal, regulatory or sector specific requirements)?

Which approach to security governance is right for me?

In practical terms, the correct approach means identifying:



Positioning of Security Governance



Why should we care about Security Governance?

1. It provides a structured approach to managing and mitigating cybersecurity risks within an organization

1. It helps protect sensitive data, maintain regulatory compliance, and enhance trust and confidence from stakeholders

1. By implementing effective security governance, organizations can reduce the likelihood and impact of security incidents, safeguarding their reputation and business operations.

What you will learn during this course

1. Models for (Information) Security Governance and “vertical” Security
2. Cyber Security Best Practices/Guidelines/Frameworks and how to use them
3. How to Assess and Manage your Risks
    1. Understanding Threats, Vulnerabilities, Attack
    2. Evaluating their impact
    3. Finding proper countermeasures
4. How to model and understand threats
5. How to manage an incident
6. Legislation compliance and Insurance
7. Research issues in Security Governance